

Post Address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(20)

Sveriges Kommuner och Regioner
registrator@skr.se

Decision after supervision according to the data protection regulation against
Sveriges Kommuner och Regioner

Contents

1. Decision of the Swedish Authority for Privacy Protection	2
2. Account of the supervisory matter	2
2.1 Background	2
2.2 Scope of IMY's examination in the matter	2
2.3 What has emerged in the matter	3
3. Justification of the decision	4
3.1 The data processed in the management of the national waiting time database constitutes personal data	4
3.1.1 Applicable provisions, etc.	4
3.1.2 SKR's information in the matter	4
3.1.3 IMY's assessment	5
3.2 The personal data constitutes health information	6
3.2.1 Applicable provision	6
3.2.2 IMY's assessment	6
3.3 SKR is the data controller for the processing of personal data in the management of the national waiting time database	7
3.3.1 Applicable provisions, etc.	7
3.3.2 SKR's information in the matter	8
3.3.3 IMY's assessment	9
3.4 SKR lacks legal basis for the processing of personal data according to Article 6 of the data protection regulation	11
3.4.1 Applicable provisions, etc.	11
3.4.2 IMY's assessment	12
3.5 SKR processes sensitive personal data in violation of Article 9 of the data protection regulation	15
3.5.1 Applicable provisions	15

Docket Number:
DI-2021-9333
Your docket number:
21/01573
Date:
2024-12-18

Swedish Authority for Privacy Protection
Docket Number: DI-2021-9333
2(20)
Date: 2024-12-18

3.5.2 IMY's assessment	15
3.7 Choice of intervention	17
3.7.1 SKR shall receive a reprimand for the violations	17
3.7.2 SKR shall be prohibited from processing personal data about patients in the management of the national waiting time database	18
How to appeal	20

1. Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection finds that Sveriges Kommuner och Regioner (org. no. 222000-0315), since May 25, 2018, as the data controller, has processed personal data about patients in the management of the national waiting time database in violation of Articles 6 and 9 of the data protection regulation.

The Swedish Authority for Privacy Protection issues a reprimand to Sveriges Kommuner och Regioner based on Article 58.2 b of the data protection regulation for the identified violations.

The Swedish Authority for Privacy Protection prohibits, based on Article 58.2 f of the data protection regulation, Sveriges Kommuner och Regioner from processing personal data about patients in the management of the national waiting time database.

The prohibition will take effect 24 months after this decision becomes final.

2. Account of the supervisory matter

2.1 Background

The Swedish Authority for Privacy Protection (IMY) initiated supervision against Sveriges Kommuner och Regioner (SKR) on November 8, 2021, with the aim of reviewing the processing of personal data in the management of the national waiting time database. After initial correspondence, an inspection was conducted on April 26, 2022, at SKR's premises to have relevant IT systems presented to IMY and to verify the processing of personal data occurring in the management of the national waiting time database.

2.2 Scope of IMY's examination in the matter

IMY's examination in the matter is limited to the following questions:

- Do the data processed in the management of the national waiting time database constitute personal data, and if so, do the personal data constitute health information?
- If personal data is processed in the management of the national waiting time database, is SKR the data controller for the processing?
- If SKR is the data controller for the processing, is the processing in accordance with the provision on legal basis in Article 6.1 of the data protection regulation?

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

3(20)

Date: 2024-12-18

the General Data Protection Regulation and the provision regarding the processing of sensitive personal data in Article 9 of the General Data Protection Regulation?

SKR has managed the waiting time database in its current form since 2010. Since the General Data Protection Regulation began to apply on May 25, 2018, IMY's examination under the General Data Protection Regulation is limited to the time thereafter. The processing of personal data related to the maintenance of the waiting time database before May 25, 2018, is therefore outside IMY's supervision. The supervision only covers the question of SKR's responsibility for the processing of personal data in the maintenance of the waiting time database. The potential responsibility of other actors – for example, the regions – for the processing of personal data is therefore not covered by IMY's supervision.

2.3 What has emerged in the case

SKR has stated the following in the matter.

The regions have a legal obligation under law and regulation to report data on waiting times to the national waiting time database maintained by SKR. The statutory obligation to report is supplemented by models that SKR has developed in collaboration with the regions. Agreements between SKR and the state state that there are models for monitoring availability, and that the regions shall report data to SKR and the waiting time database in accordance with these. SKR has managed the waiting time database in its current form since the care guarantee came into force in 2010.

The purpose of the processing of personal data is to make statistics on accessibility to Swedish healthcare available in order to monitor how the statutory care guarantee is fulfilled. The waiting time database contains compiled statistics on accessibility to Swedish healthcare. The statistics are open for everyone to access but are primarily aimed at decision-makers and practitioners within healthcare (elected representatives and officials) as well as community watchdogs.

The waiting time database contains personal data, but only the region that has reported the data has the ability to identify individual patients in the waiting time database.

SKR is not the data controller for the processing of personal data that takes place in the national waiting time database. The data controllers are Sweden's 21 regions. The processing in the database is carried out on behalf of the regions with data processing agreements (including instructions) between each data controller region and SKR.

SKR believes, in its role as a data processor, that the processing in the waiting time database is based on Article 6.1 c (legal obligation) and 6.1 e (task carried out in the public interest) as well as Article 9.2 g of the General Data Protection Regulation. Through the purpose provision in Chapter 2, Section 4 of the Patient Data Act (2008:355), PDL, it is permitted for data controllers to process personal data (including sensitive data) for statistical purposes, among other things. Furthermore, data controllers may, in accordance with Chapter 2, Section 5 of PDL, process personal data to fulfill reporting obligations under law or regulation. The processing of personal data that SKR performs as a data processor is based on a data processing agreement between the regions and SKR. Furthermore, there are provisions in Chapter 9, Section 3 of the Health and Medical Services Act (2017:30), HSL, and Chapter 6, Section 3 of the Health and Medical Services Ordinance (2017:80), HSF, which state that Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

4(20)

Date: 2024-12-18

The provision of information shall be fulfilled by the regions providing data on waiting times to the national waiting time database maintained by SKR. The processing is also based on government decisions regarding agreements on waiting times in healthcare, in which the criteria for reporting personal data are established. Such agreements state that there are models for monitoring availability and that the regions shall report data to SKR and the waiting time database in accordance with these. SKR further believes, in its role as a data processor, that the rights and interests of the registered individuals are protected through confidentiality obligations, both through data processing agreements and through the Act (2020:914) on confidentiality in outsourcing technical processing or storage of data.

3. Justification of the Decision

3.1 The data processed in the maintenance of the national waiting time database constitutes personal data

For the General Data Protection Regulation (GDPR) to be applicable in this matter, it is required that the data processed in the maintenance of the national waiting time database constitutes personal data.

3.1.1 Applicable Provisions, etc.

According to Chapter 9, Section 3 of the Health and Medical Services Act (HSL), the regions shall report data on waiting times to a national database. The reporting obligation shall be fulfilled according to Chapter 6, Section 3 of the Health and Medical Services Act (HSF) by the regions providing data on

waiting times to the national waiting time database maintained by the Swedish Association of Local Authorities and Regions.

The National Board of Health and Welfare may, according to Chapter 6, Section 4 of the HSF, issue further regulations regarding the regions' reporting obligation under Chapter 9, Section 3 of the HSL. The National Board of Health and Welfare has not issued such regulations or developed national guidelines concerning the reporting obligation.

According to Article 4.1 of the General Data Protection Regulation, personal data refers to any information relating to an identified or identifiable natural person, where an identifiable natural person is one who can be identified, directly or indirectly, particularly by reference to an identifier such as a name, an identification number, location data, online identifiers, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person. Recital 26 of the General Data Protection Regulation states that personal data that has been pseudonymized and could be attributed to a natural person by the use of additional information should be considered as data concerning an identifiable natural person. The same recital further states that, in order to determine whether a natural person is identifiable, all means that could reasonably be used by either the data controller or another person to identify the natural person, directly or indirectly, should be taken into account.

3.1.2 SKR's Role in the Matter

The waiting time database handles data on healthcare contacts (planned/waiting and completed/production), age, but where two regions report age ranges, gender,

2 The Swedish Association of Local Authorities and Regions changed its name on November 27, 2019, to the Swedish Association of Local Authorities and Regions.

3 In the context of the supervisory matter, IMY has approached the National Board of Health and Welfare, which provided a statement on May 15, 2023.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

5(20)

Date: 2024-12-18

Unit for Care Contact, Action Codes in the form of KVÅ Codes, and Diagnosis Codes according to ICD10SE.

Information about the care unit consists of location in the form of county and municipality, hospital code, and clinic code according to the National Board of Health and Welfare's classification, as well as HSA-ID. From the so-called HSA catalog for SKR, information about which care units have been reported by the regions, that is, care unit ID.

Personal data stored in the system consists of anonymized care contact, age, gender, municipality of residence, type of care, diagnoses according to ICD-10, and actions in the form of KVÅ codes.

For each data entry reported by the regions, the regions themselves choose a care contact ID that serves as a code key. The care contact ID is the information that allows the regions to link the data to a patient. SKR does not have access to the code keys that connect the reported data with the original information in the regions' journal and appointment systems.

Personal data is processed to make calculations regarding both waiting for care and completed visits. This is done by SKR also collecting information about when the waiting time began and ended.

By aggregating data in intervals, it is ensured that it is not possible to identify individual persons. Thus, it is ensured that SKR, in its capacity as a data processor, cannot use this data to identify individual individuals in the waiting time database.

3.1.3 IMY's Assessment

Crucial to the question of whether the data processed in the management of the national waiting time database constitutes personal data is whether the data pertains to identified or identifiable natural persons. As stated in Recital 26 of the General Data Protection Regulation, it is not required that the processing concerns, for example, names or personal identification numbers, but also information that has been coded but can be linked to a natural person with the help of supplementary information

constitutes personal data, provided that someone could reasonably use such supplementary information to identify the person.

IMY shares SKR's view that the data processed in the management of the waiting time database constitutes personal data since the care contact ID enables the regions to link data to a patient. The regions also have the authority to access the reported data and thus a real possibility to identify the patients.

According to IMY, there are also reasons to assess whether the data constitutes personal data even without considering the care contact ID. IMY notes that personal data can consist of one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of the natural person.

In addition to the care contact ID, data concerning the unit for care contact, action codes in the form of KVÅ codes, and diagnosis codes in the form of ICD10SE are also processed.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

6(20)

Date: 2024-12-18

The unit for healthcare contact consists of information about counties and municipalities, hospital codes, and clinic codes according to the classification by the National Board of Health and Welfare, as well as HSA-ID.

KVÅ codes consist of information about actions in healthcare that are patient-oriented interventions primarily carried out for investigative, therapeutic, or preventive purposes. A medical physical examination, such as listening to a patient's heart or lungs, is an investigative action. Surgical procedures, such as appendectomy or cataract surgery, are examples of therapeutic actions. Support for quitting smoking is a preventive action.

ICD (International Statistical Classification of Diseases and Related Health Problems) is a classification system aimed at enabling the classification and statistical description of diseases and other health problems that cause human death or contacts with healthcare services. In addition to traditional diagnoses, the classification includes a wide range of symptoms, abnormal findings, complaints, and social conditions. The Swedish version of ICD-10 is called ICD-10-SE, International Statistical Classification of Diseases and Related Health Problems – systematic list.

Furthermore, information about patients' age, gender, municipality of residence, type of care, and details about when the waiting time began and ended is processed. IMY assesses that the information processed collectively is sufficiently distinguishing regarding individual patients that the data in many cases allows for the identification of individual patients. Personal data is therefore processed in the management of the waiting time database even in the absence of information about healthcare contact ID.

What SKR has stated about individuals not being identifiable by SKR because the data is aggregated in intervals does not affect IMY's assessment in this regard since the data is also processed by SKR in non-aggregated form.

In summary, IMY assesses that the information processed in the management of the national waiting time database constitutes personal data.

3.2 Personal data constitutes health information

3.2.1 Applicable provision

According to Article 4.15 of the General Data Protection Regulation, health information refers to personal data concerning the physical or mental health of a natural person, including the provision of health and healthcare services, which provides information about their health status.

3.2.2 IMY's assessment

As mentioned above, the information reported to the national waiting time database includes, among other things, information about the care unit, type of care, diagnoses, and

4 Information on the National Board of Health and Welfare's website indicates that the National Board has compiled codes used in the patient register for hospitals and clinics, <https://www.socialstyrelsen.se/statistik-och-data/klassifikationer-och-koder/andra-kodverk/sjukhuskoder/> [2024-11-04].

5 Information on Inera AB's website indicates that the HSA catalog service is an electronic catalog that contains quality-reviewed information about organizations and individuals within healthcare and social services in Sweden, <https://www.inera.se/tjanster/alla-tjanster-a-o/hsa-katalogtjanst/> [2024-11-04].

6 Information on the National Board of Health and Welfare's website about KVA codes, <https://www.socialstyrelsen.se/statistik-och-data/klassifikationer-och-koder/kva/> [2024-11-04].

7 Information on the National Board of Health and Welfare's website about the disease classification ICD, <https://www.socialstyrelsen.se/statistik-och-data/klassifikationer-och-koder/icd-10/> [2024-11-04].

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

7(20)

Date: 2024-12-18

measures. IMY notes that this concerns data relating to a physical person's physical or mental health and that provides information about their health status. In the management of the waiting time database, health data is thus processed according to Article 4.15 of the Data Protection Regulation.

3.3 SKR is the data controller for the processing of personal data in the management of the national waiting time database

3.3.1 Applicable provisions, etc.

According to Article 4.7 of the Data Protection Regulation, a data controller is a natural or legal person, public authority, institution, or other body that alone or jointly with others determines the purposes and means of processing personal data. Furthermore, the article states that if the purposes and means of processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be designated may be prescribed in Union law or in the national law of the Member States.

According to Article 4.8 of the Data Protection Regulation, a data processor is a natural or legal person, public authority, institution, or other body that processes personal data on behalf of the data controller.

In the European Data Protection Board (EDPB) guidelines regarding the concepts of data controller and data processor, the following is stated, among other things. The concepts of data controller and data processor are functional concepts: they aim to allocate responsibility according to the actual roles of the parties. This means that an actor's legal status as either a "data controller" or a "data processor" must, in principle, be established by their actual activities in a specific situation, rather than by the formal designation of an actor as either a "data controller" or a "data processor" (e.g., in a contract). This implies that the role distribution should typically derive from an analysis of the actual elements or circumstances of the case and is not negotiable as such.

In assessing who determines the purposes and means, the EDPB distinguishes between two categories of situations: control arising from legal provisions and control arising from actual influence. In the absence of control following from legal provisions, a party's qualification as a data controller must be established based on an assessment of the actual circumstances surrounding the processing. All relevant actual circumstances must be considered to reach a conclusion about whether a particular entity exerts a decisive influence regarding the processing of the personal data in question.

The guidelines state, among other things, the following regarding control arising from legal provisions. There are cases where control can be inferred from explicit legal competence, e.g., when the data controller or the specific criteria for their nomination are established by national legislation or Union law. Where the

8 EDPB Guidelines 07/2020 on the concepts of data controller and data processor in the GDPR, version 2.0, adopted on July 7, 2021, p. 10.

9 EDPB Guidelines 07/2020 on the concepts of data controller and data processor in the GDPR, version 2.0, adopted on July 7, 2021, p. 12.

10 EDPB Guidelines 07/2020 on the concepts of data controller and data processor in the GDPR, version 2.0, adopted on July 7, 2021, p. 13.

11 Guidelines 07/2020 on the concepts of data controller and data processor in the GDPR, version 2.0, adopted on July 7, 2021, p. 12 f.

The data controller has been specifically identified by this legislation; this will be determinative for establishing who acts as the data controller. However, it is more common that instead of directly appointing the data controller or establishing the criteria for the appointment, the law will assign a task or impose an obligation to collect and process certain data. In such cases, the purpose of the processing is often determined by prevailing legislation. The data controller will normally be the one designated by prevailing legislation to carry out this purpose, this public commitment. In such cases, the law indicates, albeit indirectly, who is the data controller. More generally, the law may also impose either public or private entities to retain or provide certain data. These entities would then typically be regarded as data controllers with respect to the processing necessary to fulfill this obligation. In the same guidelines, the following example is provided:

The national legislation in country A establishes an obligation for municipal authorities to provide social benefits, such as monthly payments to citizens depending on their financial situation. To implement these payments, the municipal authority must collect and process data about the applicants' financial situation. Even though the law does not explicitly state that the municipal authority is the data controller for this processing, this is implied by the legal provisions.

3.3.2 SKR's Responsibilities in the Matter

It is the regions and not SKR that are the data controllers for the data processing that occurs in the national waiting time database. SKR's processing in the database is carried out on behalf of the regions under a data processing agreement between each data controller region and SKR.

The regions determine which processing activities will be conducted in the waiting time database. As data controllers, the regions assign various tasks to SKR, acting as a data processor. Joint preparation of the relevant tasks is conducted by the regions through a network structure with associated working and preparation groups. Additionally, there is a regional steering group, with a regional representative serving as the chairperson. SKR, together with the regions, has developed models that the regions are to report in accordance with. The steering groups' tasks encompass not only the models but also the overall and long-term strategic needs for monitoring the accessibility of care. SKR operates on behalf of the regions according to the described network structure. Decisions regarding framework funding for the waiting time database are made annually through an agreement between the state and SKR as an agent for the regions, as well as through additional funding from the regions. Technical and organizational issues related to the nationally shared work with the waiting time database have been delegated to SKR by the regions.

According to agreements between SKR and the state, the regions must report data in accordance with the developed models for monitoring accessibility to receive funding under the agreement. However, SKR cannot in any way compel the regions to report.

Description of the System and Processing

The regions' reporting to the waiting time database occurs in such a way that the regions collect data from their journal and appointment systems and send the information to Signe, which is a system managed by SKR, where the data from the regions is stored. In

Signe contains data from the current year and the previous year. Signe has been in existence since 2007 and has gradually developed. Signe communicates with the waiting time database and with the analysis tool QlikView, which is used to display the data contained in Signe.

QlikView is a proprietary database, and raw data exists in both Signe and QlikView. The analysis tool is found in QlikView, where the aggregations are made. In QlikView, there are both the open application and the detailed application.

In the open application in QlikView, the regions can see data about all regions at an aggregated level for comparison purposes. The detailed application in QlikView is fundamentally similar to the open application, but the content is somewhat different. The detailed application does not consist of aggregated data but of actual figures concerning each region. When logging in as a region, data about one's own region is displayed in the detailed application, but data from other regions is also shown down to the filtering level of clinic. In the detailed application, it is also possible to see diagnosis codes. The detailed application is primarily used for deeper analysis than the open application, as it allows for filtering at a more detailed level than in the open application. The detailed application also has a tab called data quality, under which SKR can make reasonableness assessments regarding the provided data, e.g., concerning the number of visits.

When the applications in QlikView are used, processing of the entire database occurs.

To be able to develop healthcare, SKR provides feedback to the regions based on the calculations made by SKR, by returning data about the goal fulfillment that SKR has calculated. The purpose of this part for SKR is the development of operations and accessibility.

SKR has three permissions for the detailed application. The regions contact SKR when they need assistance in understanding how to use the application and to get more out of their own data. The region (through appointed waiting time coordinators) decides who should have access to the region's detailed data and the various applications/reports.

3.3.3 IMY's Assessment

The question that IMY has to consider in this part is whether SKR is the data controller for the processing of personal data that occurs in the management of the national waiting time database, i.e., the processing in the waiting time database and the systems established to receive and process the data from the regions.

SKR's view is that SKR acts as a data processor regarding the processing of personal data in the management of the waiting time database and has submitted several data processing agreements in support of this. However, according to IMY, similar to what is stated in the EDPB's guidelines, a party's legal status as either a data controller or a data processor must be determined by the actual circumstances of the case, rather than by the formal designation of a party as either a data controller or a data processor in, for example, a contract. The submitted data processing agreements are therefore of no decisive significance for the question of whether SKR is the data controller for the processing in question.

SKR has also stated that the regions partially finance the waiting time database and that it is the regions that, together with SKR, have developed the models according to which the regions...

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

10(20)

Date: 2024-12-18

must report information. The question of whether SKR is to be considered as the data controller is, however, not dependent on the assessment of whether the regions can also be regarded as data controllers for the processing, since the concept of data controller also encompasses situations where the actor in question, together with others, determines the purposes and means of the processing. As stated above in this decision, IMY's review in this matter does not include the regions' potential responsibility for data processing.

IMY notes that it has not been explicitly regulated in Swedish law that SKR or any other actor is the data controller for the personal data processing in the waiting time database. However, through Chapter 9, Section 3 of the HSL and Chapter 6, Section 3 of the HSF, SKR has been assigned by the legislator the task of processing the data on waiting times that the regions are obliged to report to the database in the national waiting time database. Furthermore, it is stated in agreements with the state that SKR shall manage the national waiting time database.

According to IMY, this means that the legislation indirectly designates SKR as responsible for the data processing necessary to maintain the waiting time database. This strongly indicates, according to IMY's assessment, that SKR is responsible for the processing of data in the database.

IMY further notes that the overarching purpose of the regions' reporting obligation has primarily been determined by the legislator. In the preparatory works for Chapter 9, Section 3 of the HSL, it is stated that the data to be reported should primarily concern information that can be used to monitor compliance with the care guarantee, and that an additional purpose of the data should be to provide information to healthcare personnel and decision-makers as well as to the population.¹² This statement was made in connection with the government noting that more detailed regulations regarding the data that the county councils should report to the database should be provided in regulations or authority directives. As previously mentioned, the National Board of Health and Welfare has been authorized through Chapter 6, Section 4 of the HSF to issue regulations regarding the regions' reporting obligation, but no such regulations have been issued.¹³ However, it can be noted that the government and SKR have provided more detailed information about the content of the reporting obligation in agreements, for example, by stating that the statistics in the waiting time database should enable comparisons of waiting times based on gender and age, and that the regions should report in accordance with the agreed models. These models have been developed by SKR together with the regions in accordance with the assignment specified in the agreement with the state. The agreements further indicate that SKR shall manage the national waiting time database and that SKR is allocated funds annually for, among other purposes, this task. According to several of the agreements, SKR shall develop the database, conduct tests and quality assurance, and develop materials for feedback and presentation. Furthermore, it is stated that the statistics in the database should enable comparisons both within and between regions, and that SKR, through guidelines and instructions developed together with the regions, shall provide support in the regions' quality assurance of data.

According to IMY, SKR can be considered to have a strong self-interest in complying with the statutory obligation to maintain the national waiting time database and to fulfill its commitments in the agreements with the state. IMY also notes that SKR has established digital systems for receiving and processing personal data.

¹² Prop. 2009/10:67 p. 46.

¹³ See the National Board of Health and Welfare's statement in the matter dated May 15, 2023.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

11(20)

Date: 2024-12-18

SKR compiles personal data and makes it available to the regions. SKR also conducts its own assessments of the reasonableness of the provided data.

In summary, IMY assesses that SKR is indirectly designated as the data controller under Chapter 9, Section 3 of the Health and Medical Services Act (HSL) and Chapter 6, Section 3 of the Health and Social Care Act (HSF), and that the factual circumstances of the case indicate that SKR has such control over the processing of personal data that it determines the purposes and means of processing personal data in the sense of the General Data Protection Regulation (GDPR). SKR is thus the data controller for the processing of personal data in the operation of the national waiting time database.

3.4 SKR does not have a legal basis for the processing of personal data according to Article 6 of the General Data Protection Regulation

3.4.1 Applicable provisions, etc.

For the processing of personal data to be lawful, it must be based on one of the legal grounds specified in Article 6.1 of the General Data Protection Regulation. When processing personal data for health and medical purposes, it is primarily Article 6.1 c (legal obligation) or 6.1 e (public interest or exercise of official authority) that may be applicable.

According to Article 6.1 c of the General Data Protection Regulation, personal data may be processed if the processing is necessary for compliance with a legal obligation to which the data controller is subject.

Article 6.1 e of the General Data Protection Regulation states that personal data may be processed if

the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller.

According to Article 6.3 of the General Data Protection Regulation, the legal basis for processing referred to in Article 6.1 c or e must be established in accordance with Union law or the national law of a Member State to which the data controller is subject. The purpose of the processing must be established in the legal basis or, in the case of processing under point 1 e, must be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller. The legal basis may contain specific provisions to adapt the application of the provisions of this regulation, including: the general conditions that shall apply to the data controller's processing, what types of data shall be processed, which data subjects are affected, the entities to which personal data may be disclosed and for what purposes, purpose limitations, storage duration, as well as types of processing and processing procedures, including measures to ensure lawful and fair processing, including for processing in other specific situations under Chapter IX.

Recital 41 of the General Data Protection Regulation states that the legal basis should be clear and precise and its application foreseeable for the individuals concerned, in accordance with the case law of the Court of Justice of the European Union and the European Court of Human Rights. The Court of Justice of the European Union has set high standards for the formulation of the legal grounds that should underpin the processing of personal data.¹⁴

¹⁴ Judgment of the Court of Justice of the European Union of February 24, 2022, *Valsts ierēmmumu dienests*, C-175/20, EU:C:2022:124, paragraph 83, where the Court states the following: "In this context, it should be noted that in order to meet the proportionality requirement laid down in Article 5.1 c of Regulation 2016/679 (see for a similar reasoning, judgment of the...

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

12(20)

Date: 2024-12-18

According to Chapter 2, Sections 1 and 2 of the Act (2018:218) with supplementary provisions to the EU General Data Protection Regulation (Data Protection Act), personal data may be processed based on Article 6.1 c and e of the Data Protection Regulation if the processing is necessary for the data controller to fulfill a legal obligation or to perform a task of public interest arising from law or other regulations, from collective agreements, or from decisions made under law or other regulations, or as part of the data controller's exercise of authority under law or other regulations.

In the preparatory works for the Data Protection Act, the following is stated, among other things. The degree of clarity and precision required regarding the legal basis for a specific processing of personal data to be considered necessary must, according to the government, be assessed on a case-by-case basis, based on the nature of the processing and the activity. Processing of personal data that does not constitute a real infringement of personal integrity may, according to the government, occur based on a legal basis that is generally formulated. However, a more significant intrusion, such as the processing of sensitive personal data within healthcare, requires that the legal basis be more specified and thus makes the intrusion foreseeable.

A legal obligation cannot constitute a legal basis for the processing of personal data if the obligation is too vague and gives the data controller too much discretion regarding how it should be fulfilled.

In assessing whether a legal obligation, a work task, or the exercise of authority follows from, for example, a legal provision, statements from the preparatory works, the purpose of the provision, and the legal context in which the provision exists may need to be considered. It is thus not only the wording of the legal text that is relevant to determine whether something follows from the law.

According to Chapter 9, Section 3 of the Health and Medical Services Act (HSL), the regions must report data on waiting times to a national database. The reporting obligation must, according to Chapter 6, Section 3 of the Health Services Act (HSF), be fulfilled by the regions providing data on waiting times to the national waiting time database maintained by SKR.

3.4.2 IMY's Assessment

IMY initially notes that SKR has stated that SKR processes personal data based on data processing agreements between SKR and the regions. However, since IMY has assessed above that SKR is the data controller for the processing of personal data in the maintenance of the national waiting time database, the data processing agreements cannot serve as support for SKR to carry out the processing.

The legal bases that may be relevant for the processing of personal data resulting from the maintenance of the national waiting time database are, according to IMY, legal obligation (Article 6.1 c of the Data Protection Regulation) and task of public interest.

22 June 2021, Saeima of the Republic of Latvia (Pricking), C-439/19, EU:C:2021:504, paragraph 98 and the case law cited therein, the regulations underlying the processing must contain clear and precise provisions that govern the scope and application of the relevant measure and specify minimum requirements, so that individuals whose personal data are disclosed are provided with sufficient guarantees that the data are effectively protected against the risks of misuse. These regulations must also be legally binding under national law and, in particular, specify under what circumstances and on what conditions a measure for the processing of such data may be taken, ensuring that the intrusion is limited to what is strictly necessary (judgment of 6 October 2020, Privacy International, C-623/17, EU:C:2020:790, paragraph 68 and the case law cited therein).

15 Prop. 2017/18:105 p. 51.

16 Cf. SOU 2017:39 p. 114 f., Article 29 Working Party's Opinion 6/2014, WP 217, p. 20 f., and the Administrative Court of Stockholm's judgment 2020-06-17 in case no. 9379-19 and 9408-19.

17 Prop. 2017/18:105 p. 188 f.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

13(20)

Date: 2024-12-18

(Article 6.1 e of the General Data Protection Regulation). As mentioned above, the legal obligation or task of public interest according to Article 6.3 of the General Data Protection Regulation must be established in Union law or national law.

IMY notes that, in accordance with what SKR has stated, there are regulations in the PDL that allow for the processing of personal data for, among other things, statistical purposes and to fulfill reporting obligations under law or regulation. However, since it is clear from Chapter 1, Section 1 of the PDL that the law only pertains to the processing of personal data by healthcare providers and SKR is not a healthcare provider, the provisions in the PDL cannot constitute a legal basis for the processing of personal data in the matter at hand.

The question then is whether the provisions in Chapter 9, Section 3 of the HSL and Chapter 6, Section 3 of the HSF can constitute a legal basis for the processing.

The requirement for the formulation of the legal basis is higher if it concerns processing that entails a more significant intrusion. IMY notes that SKR processes personal data about patients that the regions have collected from their journal and time systems and reported to SKR. The data being processed includes information about patients' health, i.e., sensitive personal data. The regions report over 40 million healthcare contacts per year to SKR. For example, the agreement for the year 2023 between the state and SKR indicates that the agreement includes initiatives aimed at child and adolescent psychiatry. Children's personal data deserves special protection, as children may be less aware of the relevant risks, consequences, and protective measures, as well as their rights regarding the processing of personal data.¹⁸ In light of the nature, scope, and context of the processing, IMY assesses that high demands must be placed on the clarity, precision, and predictability of the legal basis for it to serve as the foundation for the current processing.

Chapter 9, Section 3 of the HSL states that the regions must report data on waiting times to a national database, and Chapter 6, Section 3 of the HSF states that this obligation shall be fulfilled by reporting data on waiting times to the national waiting time database maintained by SKR. Through the regulation in the HSF, SKR has thus been assigned a task to receive data from the regions. IMY assesses that this is a task of public interest. The question is whether the regulation of this task can serve as the

basis for the processing of personal data in the maintenance of the waiting time database.

The preparatory works for Chapter 9, Section 3 of the HSL indicate that during the consultation process, there were explicit requests for considerations regarding privacy aspects if the reporting of waiting time data were to include personal data. However, the government stated that the data to be reported was anonymized and did not constitute personal data according to the then-applicable Personal Data Act (1998:204). Therefore, the government assessed that there were no privacy aspects to consider.¹⁹ It is thus clear from the preparatory works that the intention was not for the regions' reporting of data to SKR to include personal data. According to IMY's assessment, this alone means that the regulation in the HSL and HSF cannot serve as the basis for SKR's processing of personal data.

Furthermore, it can be noted that neither the HSL nor the HSF contains any specific provisions regarding which data should be reported, nor any provisions regarding the maintenance of the waiting time database itself. The National Board of Health and Welfare has not issued any additional regulations regarding the reporting obligation. This means that,

18 Recital 38 of the General Data Protection Regulation.

19 Prop. 2009/10:67 p. 46.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

14(20)

Date: 2024-12-18

even though the regulation aimed to enable the processing of personal data, the provisions in Chapter 9, Section 3 of the HSL and Chapter 6, Section 3 of the HSF lack the clarity, precision, and predictability required to serve as a basis for the extensive and privacy-sensitive processing of personal data that is relevant in this case.

SKR has further stated that the processing occurs based on government decisions regarding agreements with SKR.

As reported, the regulation in Chapter 9, Section 3 of the HSL and Chapter 6, Section 3 of the HSF does not aim to support the processing of personal data. This means that the agreements cannot support the processing as a complement to the statutory regulation.

IMY does not assess that the government's decision to enter into agreements with SKR can constitute a legal basis for the processing on its own. According to Chapter 2, Sections 1 and 2 of the Data Protection Act, personal data may be processed based on Article 6.1 c and e of the General Data Protection Regulation if the processing is necessary for the data controller to fulfill a legal obligation or to perform a task of public interest arising from, among other things, decisions made under the authority of law or other regulations. In the preparatory works for the Data Protection Act, it is indeed stated that a government decision can constitute such a decision referred to in Chapter 2, Sections 1 and 2 of the Data Protection Act and can thus serve as a legal basis for the processing of personal data. As an example, the situation is mentioned where a task of public interest is assigned to a government authority or a state-owned company through a government decision. However, in the present case, according to IMY's assessment, it is not a matter of government decisions that establish a task of public interest. The government decisions are instead decisions to enter into an agreement negotiated with SKR, respectively decisions to delegate to a certain person to enter into such an agreement. The relevant agreements are therefore, in IMY's opinion, primarily of a civil law nature and cannot meet the requirement in Article 6.3 of the General Data Protection Regulation that a task of public interest must be established in national law.

Furthermore, IMY believes that the government's decision to enter into the relevant agreements lacks sufficient clarity, precision, and predictability to serve as a basis for the personal data processing relevant in this case. The agreements do state that reporting shall occur in accordance with the models that SKR has developed together with the regions. However, according to IMY, the models can be considered difficult to overview for a data subject. Moreover, they are not attached to the agreements and cannot be considered accessible to the data subject. The agreements are also entered into annually, which in itself implies reduced predictability.

In summary, IMY assesses that SKR cannot support the processing under Article 6.1 c or e of the General Data Protection Regulation. It has also not been established that SKR has support for the processing under any of the other legal bases in Article 6.1 of the General Data Protection Regulation. SKR thus lacks a legal basis for the processing of patients' personal data in maintaining the national waiting time database. This means that SKR has processed personal data in violation of Article 6 of the General Data Protection Regulation since May 25, 2018.

20 Cf. Recital 41 of the General Data Protection Regulation and Article 6.3 of the General Data Protection Regulation.

21 Prop. 2017/18:105 p. 188 ff.

Swedish Authority for Privacy Protection

Case Number: DI-2021-9333

15(20)

Date: 2024-12-18

3.5 SKR processes sensitive personal data in violation of Article 9 of the Data Protection Regulation

3.5.1 Applicable Provisions

Data concerning health constitutes so-called sensitive personal data. According to Article 9.1 of the Data Protection Regulation, it is prohibited to process such personal data unless the processing falls under one of the exceptions in Article 9.2.

According to Article 9.2 g of the Data Protection Regulation, sensitive personal data may be processed if the processing is necessary for reasons of substantial public interest, based on Union law or the national law of the Member States, which must be proportionate to the intended purpose, compatible with the essential content of the right to data protection, and include provisions for appropriate and specific measures to ensure the fundamental rights and interests of the data subject.

Article 9.2 h states that sensitive personal data may be processed if the processing is necessary for reasons related to preventive health care and occupational medicine, the assessment of an employee's work capacity, medical diagnoses, the provision of health care, treatment, social care, or the management of health care services and social care and their systems, based on Union law or the national law of the Member States or under agreements with professionals in the health sector, provided that the conditions and safeguards referred to in paragraph 3 are met.

A prerequisite for the processing of sensitive personal data under Article 9.2 h to be permissible is, according to Article 9.3, that the personal data is processed by or under the responsibility of a professional bound by confidentiality under Union law or the national law of the Member States or provisions established by national competent authorities or by another person who is also bound by confidentiality under Union law or the national law of the Member States or provisions established by national competent authorities.

3.5.2 IMY's Assessment

IMY initially notes that a prerequisite for the processing of sensitive personal data to be lawful under any of the points in Article 9.2 is that the processing has a legal basis under Article 6.22 Since IMY has assessed above that SKR lacks a legal basis under Article 6, it can already be concluded for that reason that the processing of personal data is also not permitted under Article 9.

According to IMY, there are reasons to still assess whether any of the points in Article 9.2 may be applicable if a legal basis under Article 6 had existed.

IMY assesses that the personal data processing in question is related to health care in the sense referred to in Article 9.2 h. In the literature, it has been stated that the enumeration of purposes in Article 9.2 h will practically cover almost all processing of sensitive personal data occurring within the health care sector.²³ In the Swedish legislative work, it has been stated regarding the corresponding provision in the Data Protection Directive²⁴ that it is not reasonable to give the provision an overly broad interpretation.

²² Judgment of the Court of Justice of the European Union on December 21, 2023, *Krankenversicherung Nordrhein*, Case C-667/21, ECLI:EU:C:2023:1022, p. 79.

23 Öman, Data Protection Regulation (GDPR) etc. (version 2B, JUNO), commentary on Article 9.2 h.
24 Directive 95/46/EC of the European Parliament and of the Council of October 24, 1995, on the protection of individuals with regard to the processing of personal data and on the free movement of such data.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

16(20)

Date: 2024-12-18

narrow scope and that activities related to health and medical care outside the primary care area must also be included.²⁵ IMY believes that, in this context, Article 9.2 h of the General Data Protection Regulation (GDPR) may be applicable to the processing. A prerequisite for sensitive personal data to be processed under Article 9.2 h is, according to Article 9.3, that there is a statutory confidentiality obligation. SKR has stated that the rights and interests of the registered individuals are protected by confidentiality obligations, both through data processing agreements and through the law on confidentiality in outsourcing technical processing or storage of data. IMY has previously assessed that SKR is not a data processor in relation to the regions and notes that confidentiality obligations according to agreements are not sufficient to meet the requirements of Article 9.3 of the GDPR. SKR's processing of personal data does not solely constitute technical processing or storage on behalf of an authority, which is why the law on confidentiality in outsourcing technical processing or storage is not applicable.²⁶ SKR is also not a healthcare provider, and the organization's staff are not covered by confidentiality obligations under the Patient Safety Act (2010:659). It has not been established that SKR's staff are subject to confidentiality obligations under any other regulation. Against this background, IMY assesses that the conditions for processing sensitive personal data under Article 9.2 h are not met.

IMY notes that SKR has claimed that the processing of sensitive personal data relies on Article 9.2 g because it concerns an important public interest at a general level that regulations regarding waiting times should be able to be monitored by those affected. However, IMY assesses that the conditions for processing personal data under that article are also not met. A prerequisite for Article 9.2 g to be applicable is that the regulation in national law supporting the processing contains provisions on appropriate and specific safeguards. Literature has stated that this implies that processing of sensitive personal data under Article 9.2 g in most cases requires support for the processing itself in a register regulation or equivalent.²⁷ In register regulations, there are usually provisions on protective measures such as search restrictions, restrictions on electronic access, access control, log monitoring, and restrictions on what may be more generally available within the relevant organization. No such provisions exist in Chapter 9, Section 3 of the Health and Medical Services Act (HSL) or Chapter 6, Section 3 of the Health and Social Care Act (HSF). IMY assesses—especially considering the large amount of sensitive personal data handled in the operation of the national waiting time database—that there are insufficient safeguards for the processing of sensitive personal data to be lawful under Article 9.2 g.

It has also not been established that the processing of sensitive personal data could occur under any other point in Article 9.2 of the GDPR. In summary, IMY assesses that SKR has been processing personal data in violation of Article 9 of the GDPR since May 25, 2018.

25 Prop. 2005/06:70 p. 144.

26 Section 1 of the law on confidentiality in outsourcing technical processing or storage of data.

27 Öman, General Data Protection Regulation (GDPR) etc. (version 2B, JUNO), commentary on Article 9.2 g.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-9333

17(20)

Date: 2024-12-18

3.7 Choice of Intervention

3.7.1 SKR shall be given a reprimand for the violations

According to Article 58.2 and Article 83.2 of the General Data Protection Regulation (GDPR), IMY has the authority to impose administrative fines in accordance with Article 83. Depending on the circumstances of the individual case, administrative fines may be imposed in addition to or instead of the other measures referred to in Article 58.2, such as orders or prohibitions. Furthermore, Article 83.2 specifies the factors that should be considered when deciding whether administrative fines should be imposed and when determining the amount of the fine. The imposition of an administrative fine shall, according to Article 83.1, in each individual case be effective, proportionate, and dissuasive. If it concerns a minor violation, IMY may, as stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b. Consideration should be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the violation, as well as previous relevant violations.

IMY has determined that SKR receives a substantial amount of personal data about patients from the regions' journal and time systems. The reporting from the regions includes over 40 million healthcare contacts per year. This involves personal data about individuals, including children, and their health. The staff at SKR are not subject to any statutory confidentiality obligation. According to IMY, SKR's violations of Articles 6 and 9 of the GDPR are of such a nature that the violations should normally lead to an administrative fine.

However, in this supervisory matter, there are circumstances that argue against a fine. SKR has managed the waiting time database in its current form since the care guarantee came into force in 2010. The regions' reporting to the waiting time database is regulated by law and is also based on agreements between the state and SKR. The preparatory works indicated that there should be more detailed regulations in the regulation or authority regulations regarding the data that the county councils should report to the database.²⁸ The National Board of Health and Welfare, which according to Chapter 6, Section 4 of the HSF may issue further regulations regarding the regions' reporting obligation according to Chapter 9, Section 3 of the HSL, has not issued any regulations nor has it developed national guidelines concerning the reporting obligation. Furthermore, SKR and the government have entered into agreements regarding the management of the national waiting time database. This collectively means that SKR had some justification for perceiving that the processing of personal data in the management of the waiting time database was lawful.

In the supervisory matter, it has also emerged that while SKR processes personal data reported by the regions, it does not involve direct personal data in the form of patients' names or personal identification numbers, which also speaks in a mitigating direction.

Against this background, IMY assesses that it is not proportionate to impose a fine on SKR. SKR shall therefore, based on Article 58.2 b of the GDPR, be given a reprimand for the identified violations of Articles 6 and 9 of the GDPR.

28 Prop. 2009/10:67 p. 45.

Swedish Authority for Privacy Protection

Case Number: DI-2021-9333

18(20)

Date: 2024-12-18

3.7.2 SKR shall be prohibited from processing personal data about patients in the management of the national waiting time database.

The next question is whether IMY should also decide on an injunction or prohibition to ensure that the illegal processing of personal data ceases.

According to Article 58.2 d of the General Data Protection Regulation (GDPR), the supervisory authority may order the data controller or data processor to ensure that processing is carried out in accordance with the provisions of the regulation and, if necessary, in a specific manner and within a specific period. According to Article 58.2 f, the supervisory authority may impose a temporary or permanent limitation on, including a prohibition against, processing.

SKR's processing of personal data in the management of the national waiting time database is in violation of the GDPR and involves the processing of sensitive personal data about a large number of

individuals without adequate statutory protective measures. This indicates that IMY should exercise its corrective powers to ensure that the illegal processing of personal data ceases.

A prohibition on processing is an intrusive measure that should be applied restrictively and only if the deficiencies are such that they cannot be remedied in any other way than by ceasing the processing.²⁹ However, IMY notes that the lack of legal support for the current processing of personal data under Articles 6 and 9 of the GDPR cannot be remedied by an injunction requiring that the processing be carried out in a specific manner according to Article 58.2 d. There are therefore grounds to decide on a prohibition against the illegal processing of personal data.

It can, however, be noted that a prohibition on the processing of patients' personal data in the management of the national waiting time database would have significant consequences not only for SKR but also for the regions, the state, and individual citizens. The purpose of the follow-up in the waiting time database is to provide a basis for operational development and the possibility of comparisons both within and between regions, which in turn enables the development and improvement of healthcare accessibility.³⁰ In the agreement between the state and SKR for the year 2023, it is stated that the government allocates over three billion kronor annually to support the regions' efforts to shorten waiting times and healthcare queues, with the aim of ensuring that more patients receive care in a reasonable time. Even though IMY has assessed that SKR lacks legal support for the processing under the current regulation, there is thus a significant public interest in the national waiting time database.

Against this background, IMY assesses that a prohibition can only be proportionate if it is accompanied by a sufficiently long deadline for the prohibition to take effect. This allows for the development of national provisions that provide SKR with legal support for the ongoing processing of personal data in the waiting time database.³¹ It also enables SKR to take measures to ensure that personal data is not processed in the management of the national waiting time database.

29 Cf. Prop. 2017/18:232 p. 297 regarding the corresponding provision in the Criminal Data Act (2018:1177).

30 Prop. 2019/20:164 p. 47.

31 IMY notes in this context that the Inquiry on Health Data Registers has proposed that the state's need for follow-up on waiting times should be met through an expansion of the reporting of data to the patient register maintained by the National Board of Health and Welfare. The inquiry does not question the regions' continued need for the waiting time database with its current content and functions but believes that it can be questioned whether the statutory reporting obligation to the waiting time database can be justified when the state's need is covered by the collection of data in the patient register as proposed by the inquiry. Therefore, the inquiry believes that the government should consider abolishing the regions' reporting obligation to the waiting time database under Chapter 9, Section 3 of the Health and Medical Services Act (SOU 2024:57 p. 200 f).

Swedish Authority for Privacy Protection

Case Number: DI-2021-9333

19(20)

Date: 2024-12-18

IMY assesses that 24 months after this decision has gained legal force is an appropriate time period. Against this background, SKR shall, based on Article 58.2 f of the GDPR, be prohibited from processing personal data about patients in the management of the national waiting time database. The prohibition shall take effect 24 months after this decision has gained legal force.

This decision has been made by the Director General Eric Leijonram after presentation by the department lawyer Andreas Persson. In the final processing, the legal manager David Törngren, unit manager Linn Sandmark, lawyer Cecilia Agnehall, and senior IT and information security specialist Magnus Bergström have also participated.

Eric Leijonram

Copy to

Data Protection Officer
Ministry of Social Affairs
National Board of Health and Welfare

Swedish Authority for Privacy Protection

Case Number: DI-2021-9333

20(20)

Date: 2024-12-18

How to appeal

If you wish to appeal the decision, you should write to IMY. Indicate in the letter which decision you are appealing and the amendment you are requesting. The appeal must be received by IMY within three weeks from the day you were informed of the decision. However, if you are a party representing the public interest, the appeal must be received within three weeks from the day the decision was announced. If the appeal has been submitted in a timely manner, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.